

รายงาน

เรื่องการออกแบบและพัฒนาระบบรักษาความมั่นคงปลอดภัยแบบหลายชั้น

คณะผู้จัดทำ

นางสาวกัญญาณัฐ	จันทร์สูงเนิน	รหัสนักศึกษา 67160059
นางสาวณัฐนรินทร์	น้ำเพ็ชร์	รหัสนักศึกษา 67160091
นายเมธาสิทธิ์	กองคำ	รหัสนักศึกษา 67160103
นายกัณพิทักษ์	ชลศิริวานิช	รหัสนักศึกษา 67160247
นายกิตติณัฏฐ์	ประพันธ์	รหัสนักศึกษา 67160249
นางสาววิไลลักษณ์	แก้วขาว	รหัสนักศึกษา 67160270
นางสาวชิษณุภรณ์	เลืองวัน	รหัสนักศึกษา 67160418
นางสาวธนกร	ลือภูวพิทักษ์กุล	รหัสนักศึกษา 67160421

เสนอ

ผศ. ภูสิต กุลเกษม

รายงานฉบับนี้เป็นส่วนหนึ่งของวิชา 88633065 เครือข่ายคอมพิวเตอร์ (Computer Networks)

หลักสูตรปริญญาวิทยาศาสตรบัณฑิต สาขาวิทยาการคอมพิวเตอร์ คณะวิทยาการสารสนเทศ

มหาวิทยาลัยบูรพา ภาคเรียนที่ 1 ปีการศึกษา 2569

คำนำ

รายงานฉบับนี้จัดทำขึ้นเพื่อนำเสนอผลการดำเนินงานการออกแบบ ติดตั้ง และเพิ่มประสิทธิภาพความมั่นคงปลอดภัยให้กับระบบเว็บเซิร์ฟเวอร์ ที่เปิดให้บริการสาธารณะบนโครงสร้างพื้นฐานคลาวด์คอมพิวติง (Cloud Computing) ซึ่งในปัจจุบันบันการเปิดเซิร์ฟเวอร์ผ่านเครือข่ายอินเทอร์เน็ตมักเผชิญกับความเสี่ยงจากการถูกสแกนหาช่องโหว่และการพยายามเจาะระบบจากผู้ไม่พึงประสงค์ทั่วโลก การป้องกันระดับพื้นฐานจึงไม่เพียงพอต่อการรักษาเสถียรภาพและความปลอดภัยของข้อมูล

เนื้อหาภายในรายงานฉบับนี้ ครอบคลุมการดำเนินงานจริงตั้งแต่ระดับการสร้างเซิร์ฟเวอร์เสมือนบน Microsoft Azure การเชื่อมโยงชื่อโดเมนผ่าน Dynamic DNS (DuckDNS) การเข้ารหัสช่องทางการสื่อสารด้วยใบรับรอง TLS จาก Let's Encrypt การปรับปรุงสถาปัตยกรรมระบบด้วย Nginx Reverse Proxy ร่วมกับ Micro-caching และ Web Application Firewall (WAF) เบื้องต้น การสร้างกำแพงไฟร์วอลล์ระดับเคอร์เนลด้วย iptables ร่วมกับ ipset เพื่อจำกัดการเข้าถึงเฉพาะผู้ใช้งานภายในประเทศไทย (Geo-blocking) ตลอดจนการพัฒนาระบบปัญญาประดิษฐ์ตรวจจับและป้องกันการบุกรุก (AI-Driven IPS) ที่สามารถวิเคราะห์ Log อัตโนมัติแจ้งเตือนผ่านแพลตฟอร์มดิสคอร์ด (Discord) และสั่งแบนไอพีผู้โจมตีทันที

คณะผู้จัดทำหวังเป็นอย่างยิ่งว่ารายงานฉบับนี้จะเป็นประโยชน์ และเป็นแนวทางเชิงปฏิบัติการสำหรับนิสิตหรือผู้ที่สนใจศึกษาด้านการบริหารจัดการระบบเครือข่ายความปลอดภัย หากมีข้อผิดพลาดประการใดคณะผู้จัดทำขอน้อมรับและขออภัยมา ณ ที่นี้

คณะผู้จัดทำ

สารบัญ

เรื่อง **หน้า**

คำนำ ..... ก

สารบัญ ..... ข

สารบัญตาราง ..... ง

บทที่ 1 บทนำ **1**

1.1 ที่มาและความสำคัญ 1

1.2 วัตถุประสงค์ 1

1.3 ขอบเขตการดำเนินงาน 2

1.4 ประโยชน์ที่คาดว่าจะได้รับ 2

บทที่ 2 ทฤษฎีและเอกสารที่เกี่ยวข้อง **3**

2.1 แนวคิดสถาปัตยกรรมการป้องกันแบบหลายชั้น (Defense-in-Depth) 3

2.2 ระบบชื่อโดเมนและ Dynamic DNS (DNS & DDNS) 3

2.3 สถาปัตยกรรมเว็บเซิร์ฟเวอร์แบบ Reverse Proxy และ TLS Termination 4

2.4 กลไกการประมวลผล FastCGI และ Process Isolation (PHP-FPM) 4

2.5 ระบบตรวจจับและป้องกันการบุกรุก (Fail2Ban และ IPset) 5

2.6 การป้องกันภัยคุกคามระดับแอปพลิเคชันและเทคนิค Honeypot 5

2.7 การวิเคราะห์บันทึกเหตุการณ์ด้วย AI และการแจ้งเตือนผ่าน Discord Webhook 5

บทที่ 3 วิธีดำเนินงาน **7**

3.1 การออกแบบสถาปัตยกรรมระบบ 6 ระดับชั้น 7

3.2 การจัดเตรียมเครื่องแม่ข่ายเสมือนบนคลาวด์และการควบคุมสิทธิ์ SSH 8

3.3 การกำหนดค่าระบบแปลงชื่อโดเมนแบบพลวัต (DuckDNS) 8

3.4 การติดตั้งและการกำหนดค่า Nginx Reverse Proxy และ SSL/TLS 8

3.5 การปรับแต่งความมั่นคงปลอดภัยของเว็บเซิร์ฟเวอร์ (Nginx Hardening) 9

3.6 การติดตั้งระบบ WordPress และการเชื่อมโยง PHP-FPM 10

3.7 การกำหนดค่าระบบป้องกันการบุกรุกและการปิดกั้นเชิงภูมิศาสตร์ (Geo-blocking) 10

เรื่อง **หน้า**

3.8 การพัฒนาระบบ AI Log Analysis และการเชื่อมต่อ Discord Webhook....10
บทที่ 4 ผลการดำเนินงาน....11
4.1 ผลการทดสอบสถานะการทำงานของระบบ....11
4.2 ผลการทดสอบการเข้าถึงเว็บไซต์และใบรับรองความปลอดภัย....11
4.3 ผลการทดสอบระบบควบคุมขอบเขตตามภูมิศาสตร์ (Geo-blocking)....11
4.4 ผลการทดสอบการสกัดกั้นช่องโหว่ความปลอดภัยระดับเว็บเซิร์ฟเวอร์....12
4.5 ผลการทดสอบระบบตรวจจับ AI Log และการสั่งระงับการเชื่อมต่ออัตโนมัติ....12
บทที่ 5 สรุปผลและข้อเสนอแนะ....13
5.1 สรุปผลการดำเนินงาน....13
5.2 ข้อเสนอแนะสำหรับการพัฒนาต่อยอด....13
บรรณานุกรม....15

สารบัญตาราง

ตาราง **หน้า**

ตารางที่ 3.1 สถาปัตยกรรมความมั่นคงปลอดภัยแบบหลายชั้น 6 ระดับ 7

ตารางที่ 4.1 สถานการณ์ทำงานใช้ทรัพยากรของบริการระบบ 11

ตารางที่ 4.2 ผลการทดสอบระบบความปลอดภัยและไฟร์วอลล์ในสถานการณ์ต่าง ๆ 12

ตารางที่ 4.3 ผลการทดสอบการสกัดกั้นช่องโหว่ความปลอดภัยระดับเว็บเซิร์ฟเวอร์ 12

บทที่ 1
บทนำ

1.1 ที่มาและความสำคัญ

ปัจจุบันระบบเครือข่ายอินเทอร์เน็ต ได้กลายเป็นช่องทางหลักในการให้บริการแอปพลิเคชันและข้อมูลสารสนเทศ อย่างไรก็ตามเซิร์ฟเวอร์ที่เปิดพอร์ตการสื่อสารสู่สาธารณะ มักตกเป็นเป้าหมายของการโจมตีทางไซเบอร์ในรูปแบบต่าง ๆ ตลอดเวลา เช่น การสแกนหาไดเรกทอรีสำรีสำคัญ (.env, .git, หน้าผู้ดูแลระบบ) การยิงคำสั่ง SQL Injection ตลอดจนการยิงสุ่มรหัสผ่าน (Bruteforce Attacks) โดยกลุ่มบอตเน็ตอัตโนมัติจากต่างประเทศ ซึ่งสร้างความเสียหายต่อความลับของข้อมูลและส่งผลให้ทรัพยากรของเซิร์ฟเวอร์ถูกใช้ไปอย่างสิ้นเปลืองเพื่อแก้ปัญหาดังกล่าว

โครงงานนี้จึงมุ่งเน้นการออกแบบและพัฒนาสถาปัตยกรรมเว็บเซิร์ฟเวอร์ความปลอดภัยสูงที่มีการป้องกันเชิงลึก (Defense-in-Depth) ตั้งแต่ระดับโครงสร้างพื้นฐานเครือข่ายด้วยการจำกัดเขตแดนทางภูมิศาสตร์ (Geoblocking) อนุญาตเฉพาะไอพีแอดเดรสภายในประเทศไทย การเสริมชั้นตัวแทนย้อนกลับ (Reverse Proxy) ร่วมกับระบบแคช (Caching) และการนำเทคโนโลยีปัญญาประดิษฐ์ (AI) มาวิเคราะห์พฤติกรรมการบุกรุกจากบันทึกการเข้าถึง (Access Log) เพื่อสั่งการระงับการเชื่อมต่อของผู้ไม่พึงประสงค์แบบอัตโนมัติ (IPS Auto-Ban) และรายงานสถานะสู่ผู้ดูแลระบบแบบทันท่วงที

1.2 วัตถุประสงค์ของการดำเนินงาน

1.2.1 เพื่อติดตั้งและปรับแต่งเว็บเซิร์ฟเวอร์ Nginx บนระบบคลาวด์เสมือน พร้อมเข้ารหัสข้อมูลด้วยโปรโตคอล HTTPS 100%

1.2.2 เพื่อกำหนดกฎไฟร์วอลล์ระดับเคอร์เนลด้วย iptables และ ipset ในการสกัดกั้นการเชื่อมต่อจากนอกราชอาณาจักรไทย (Geo-blocking)

1.2.3 เพื่อปรับแต่งสถาปัตยกรรม Micro-caching, Rate Limiting และ Web Application Firewall (WAF) สกัดกั้นภัยคุกคามในระดับแอปพลิเคชัน

1.2.4 เพื่อพัฒนาระบบเฝ้าระวังและป้องกันการบุกรุกเชิงรุก (IPS) โดยใช้โมเดล AI ในการประเมินความเสี่ยงแจ้งเตือนผ่าน Discord และสั่งแบนไอพีผู้โจมตีเข้าสู่แบล็กลิสต์อัตโนมัติ

1.3 ขอบเขตการดำเนินงาน

โครงงานนี้ดำเนินการติดตั้งบนระบบปฏิบัติการ Ubuntu Linux (เครื่องเสมือนบน Microsoft Azure) โดยใช้ชื่อโฮสต์ lynxcs-vps เชื่อมโยงผ่านชื่อโดเมนเนม lynxlunarcs.duckdns.org คุ้มครองพอร์ตบริการหลัก 22 (SSH), 80 (HTTP) และ 443 (HTTPS) โดยจำกัดการเข้าถึงเฉพาะกลุ่มไอพีที่กำหนดไว้ในฐานข้อมูล IPdeny ของประเทศไทย และดักจับพฤติกรรมผิดปกติผ่านบันทึกการเข้าถึงของ Nginx

1.4 ประโยชน์ที่คาดว่าจะได้รับ

1.4.1 ได้ระบบเว็บเซิร์ฟเวอร์ที่มีความมั่นคงปลอดภัยตามมาตรฐานสากลและมีความพร้อมใช้งานสูง

1.4.2 สามารถลดปริมาณทราฟฟิกอันตรายและการสแกนช่องโหว่จากบอตเน็ตต่างประเทศได้มากกว่า 95%

1.4.3 เพิ่มความเร็วในการตอบสนองของเซิร์ฟเวอร์ด้วยระบบ Micro-caching และลดความเสี่ยงจากการโจมตีประเภท DoS

1.4.4 ช่วยให้ผู้ดูแลระบบรับทราบเหตุการณ์ความผิดปกติได้ทันทีผ่านระบบแจ้งเตือนแบบเรียลไทม์ และระบบสามารถตอบสนองตัดการเชื่อมต่อได้โดยอัตโนมัติ

บทที่ 2
ทฤษฎีและเอกสารที่เกี่ยวข้อง

ในการจัดทำรายงานการออกแบบและพัฒนาระบบรักษาความมั่นคงปลอดภัยแบบหลายชั้น คณะผู้จัดทำได้ศึกษาทฤษฎีเทคโนโลยี และเอกสารทางวิชาการที่เกี่ยวข้อง เพื่อใช้เป็นแนวทางในการดำเนินงาน ดังต่อไปนี้

2.1 แนวคิดสถาปัตยกรรมการป้องกันแบบหลายชั้น (Defense-in-Depth)

แนวคิดสถาปัตยกรรมการป้องกันแบบหลายชั้น (Defense-in-Depth) เป็นกลยุทธ์การบริหารจัดการความมั่นคงปลอดภัยสารสนเทศที่มีรากฐานมาจากการป้องกันทางการทหาร โดยมุ่งเน้นการวางมาตรการควบคุมความปลอดภัยซ้อนทับกันหลายชั้นอย่างเป็นอิสระต่อกัน เพื่อไม่ให้ระบบต้องพึ่งพาการทำงานของกลไกป้องกันเพียงจุดเดียว (Single Point of Failure) ในบริบทของระบบคอมพิวเตอร์และเครือข่ายสถาปัตยกรรมดังกล่าวจะครอบคลุมตั้งแต่ระดับขอบเขตเครือข่าย (Perimeter) ระดับระบบปฏิบัติการและเครื่องแม่ข่าย (Host) ระดับบริการเว็บและเกตเวย์ (Proxy & Web Server) ระดับสภาพแวดล้อมการประมวลผล (Runtime) ระดับแอปพลิเคชัน (Application) ไปจนถึงระดับข้อมูล (Data) หากผู้โจมตีสามารถเจาะผ่านด่านแรกเข้ามาได้ก็จะยังคงมีด่านความปลอดภัยในชั้นถัดไปคอยสกัดกั้นและแจ้งเตือน ทำให้สามารถลดโอกาสความเสียหาย และจำกัดขอบเขตของผลกระทบได้อย่างมีประสิทธิภาพ

2.2 ระบบชื่อโดเมนและ Dynamic DNS (DNS & DDNS)

ระบบชื่อโดเมน (Domain Name System: DNS) เป็นระบบฐานข้อมูลแบบกระจายศูนย์ที่ทำหน้าที่แปลงชื่อโดเมนซึ่งเป็นข้อความที่มนุษย์จดจำได้ง่าย ให้กลายเป็นหมายเลขไอพีแอดเดรส (IP Address) ที่อุปกรณ์บนเครือข่ายใช้ในการสื่อสารระหว่างกัน สำหรับการให้บริการบนเครื่องแม่ข่ายเสมือนบนคลาวด์ที่อาจมีการเปลี่ยนแปลงหมายเลขไอพี หรือสภาพแวดล้อมที่ใช้หมายเลขไอพีแบบพลวัต (Dynamic IP) การประยุกต์ใช้งาน Dynamic DNS (DDNS) จะช่วยให้อุปกรณ์แม่ข่ายสามารถส่งสัญญาณปรับปรุงหมายเลขไอพีล่าสุด ไปยังเครื่องบริการชื่อโดเมนโดยอัตโนมัติผ่านทางโปรโตคอล HTTPS REST API ส่งผลให้ชื่อโดเมนชี้ไปยังหมายเลขไอพีที่ถูกต้องตลอดเวลาและมีความพร้อมในการให้บริการอย่างต่อเนื่อง

2.3 สถาปัตยกรรมเว็บเซิร์ฟเวอร์แบบ Reverse Proxy และ TLS Termination

ตัวแทนย้อนกลับ (Reverse Proxy) คือเซิร์ฟเวอร์ที่ทำหน้าที่เป็นจุดรับคำขอ (Request) จากเครื่องลูกข่ายภายนอกเครือข่าย และทำการประมวลผลคัดกรองก่อนที่จะส่งต่อคำขอดังกล่าวไปยังเครื่องบริการแอปพลิเคชันภายในการใช้งาน Nginx ในบทบาท Reverse Proxy มีหลักการและข้อได้เปรียบทางวิศวกรรมที่สำคัญ ดังนี้

2.3.1 การสิ้นสุดการเข้ารหัสลับ (TLS/SSL Termination): Nginx ทำหน้าที่เป็นจุดรับและถอดรหัสลับข้อมูล HTTPS ด้วยใบรับรองดิจิทัล (เช่น Let's Encrypt) ก่อนส่งข้อมูลต่อไปยังแอปพลิเคชันภายในซึ่งช่วยลดภาระการประมวลผลการคำนวณทางคณิตศาสตร์ของตัวประมวลผลสคริปต์ได้อย่างมาก

2.3.2 การจำกัดอัตราการเรียกใช้งาน (Rate Limiting): การประยุกต์ใช้อัลกอริทึมจำกัดทราฟฟิก (Leaky Bucket) ช่วยควบคุมจำนวนคำขอที่อนุญาตให้ส่งเข้ามาจากแต่ละหมายเลขไอพีต่อหนึ่งหน่วยเวลา เพื่อป้องกันการโจมตีแบบปฏิเสธการให้บริการ (DoS) และการสุ่มรหัสผ่าน

2.3.3 การคัดกรองและสกัดกั้นคำขอที่เป็นอันตราย (Request Filtering): Nginx สามารถตรวจสอบส่วนหัว (Headers) พารามิเตอร์ และโครงสร้างของ Uniform Resource Identifier (URI) หากพบรูปแบบที่เข้าข่ายการโจมตี เช่น SQL Injection หรือ Cross-Site Scripting ระบบสามารถตอบกลับด้วยรหัสสถานะ HTTP 403 Forbidden ทันทีโดยไม่ส่งต่อไปยังแอปพลิเคชัน

2.3.4 การปิดบังข้อมูลระบบ (Information Masking): การปิดการส่งค่าเวอร์ชันของเว็บเซิร์ฟเวอร์ (server_tokens off) ช่วยป้องกันไม่ให้ผู้ไม่ประสงค์ดีสามารถรวบรวมข้อมูลจำเพาะของซอฟต์แวร์ (Banner Grabbing) เพื่อนำไปค้นหาช่องโหว่เฉพาะรุ่นได้

2.4 กลไกการประมวลผล FastCGI และ Process Isolation (PHP-FPM)

PHP-FPM (FastCGI Process Manager) เป็นระบบจัดการกระบวนการประมวลผลภาษา PHP ที่ออกแบบมาเพื่อรองรับงานที่มีปริมาณคำขอสูง โดยทำงานแยกส่วนออกจากเว็บเซิร์ฟเวอร์ Nginx การติดต่อสื่อสารระหว่าง Nginx และ PHP-FPM นิยมดำเนินการผ่าน UNIX Domain Socket (เช่น /run/php/php8.3-fpm.sock) ซึ่งเป็นการสื่อสารภายในระดับเคอร์เนลของระบบปฏิบัติการ (Inter-Process Communication: IPC) โดยตรง ทำให้มีความเร็วสูงกว่าการสื่อสารผ่านโปรโตคอล TCP เครือข่าย และมีความปลอดภัยสูงเนื่องจากไม่มีการเปิดพอร์ตรับข้อมูล นอกจากนี้ PHP-FPM ยังกำหนดสิทธิ์การประมวลผลภายใต้ผู้ใช้งานเฉพาะ (www-data) ซึ่งเป็นการจำกัดขอบเขตมิให้สคริปต์สามารถเข้าถึงไฟล์สำคัญของระบบปฏิบัติการได้

2.5 ระบบตรวจจับและป้องกันการบุกรุก (Fail2Ban และ IPset)

Fail2Ban เป็นระบบป้องกันการบุกรุกระดับเครื่องแม่ข่าย (Host-based Intrusion Prevention System: HIPS) ที่ทำงานโดยการเฝ้าตรวจอ่านไฟล์บันทึกเหตุการณ์ของระบบ (Log Files) อย่างต่อเนื่อง เมื่อตรวจพบว่ามีหมายเลขไอพีใดที่มีพฤติกรรมผิดปกติซ้ำ ๆ ตามเงื่อนไขของนิพจน์เรกิวลาร์ (Regular Expression) ที่กำหนดไว้ครบตามเกณฑ์ที่ระบุ Fail2Ban จะสั่งการไปยังระบบไฟร์วอลล์ของระบบปฏิบัติการเพื่อทำการปิดกั้นหมายเลขไอพีนั้นโดยอัตโนมัติ เพื่อเพิ่มประสิทธิภาพในการทำงานของระบบไฟร์วอลล์ ได้มีการนำ IPset ซึ่งเป็นเครื่องมือจัดการชุดข้อมูลหมายเลขไอพีในระดับเคอร์เนลของลินุกซ์มาประยุกต์ใช้โดยใช้โครงสร้างข้อมูลแบบตารางแฮช (Hash Table) ทำให้การตรวจสอบหมายเลขไอพีมีอัตราความเร็วคงที่ระดับ O(1) แม้ว่าจะมีจำนวนไอพีในรายการเป็นแสนรายการ จึงเหมาะสมอย่างยิ่งสำหรับการนำมาประยุกต์ใช้ในการปิดกั้นการเข้าถึงเชิงภูมิศาสตร์ (Geo-blocking) เพื่อคัดกรองทราฟฟิกให้เข้าถึงได้เฉพาะจากภายในประเทศที่กำหนด

2.6 การป้องกันภัยคุกคามระดับแอปพลิเคชันและเทคนิค Honeypot

ภัยคุกคามระดับแอปพลิเคชันบน WordPress ส่วนใหญ่เกิดจากบอทอัตโนมัติที่ส่งข้อมูลสแปม และพยายามสุ่มรหัสผ่านผ่านฟอร์มเข้าสู่ระบบ เทคนิค Honeypot เป็นกลวิธีสร้างกับดักล่อบอท โดยการแทรกฟิลด์ป้อนข้อมูลพิเศษลงในโค้ด HTML ของฟอร์มแต่ทำการซ่อนฟิลด์ดังกล่าวไว้ด้วยคำสั่ง CSS หรือ JavaScript เพื่อไม่ให้มนุษย์ที่ใช้งานผ่านเว็บเบราว์เซอร์มองเห็น สำหรับบอทอัตโนมัติที่ทำงานโดยการอ่านโครงสร้าง HTML จะกรอกข้อมูลลงในทุกฟิลด์ที่ตรวจพบ เมื่อผู้ใช้งานกดส่งข้อมูลระบบจะทำการตรวจสอบว่าหากฟิลด์กับดักดังกล่าวมีข้อมูลอยู่จะถือว่าเป็นบอทในทันทีและทำการยกเลิกคำขอนั้นโดยไม่ต้องประมวลผลต่อ เทคนิคนี้ช่วยลดภาระการทำงานของเซิร์ฟเวอร์และไม่สร้างความยุ่งยากแก่ผู้ใช้งานจริงเหมือนระบบ CAPTCHA ทั่วไป

2.7 การวิเคราะห์บันทึกเหตุการณ์ด้วย AI และการแจ้งเตือนผ่าน Discord Webhook

ไฟล์บันทึกเหตุการณ์การเข้าถึงของเว็บเซิร์ฟเวอร์ (Access Log) เป็นแหล่งข้อมูลที่มีปริมาณมหาศาล และมีความต่อเนื่อง การนำโปรแกรมภาษาไพทอนที่ผสานตรรกะการวิเคราะห์เชิงพฤติกรรมและกฎเกณฑ์การตรวจจับความผิดปกติ (Heuristic Rule-based AI Analysis) เข้ามาประมวลผลไฟล์บันทึกเหตุการณ์แบบทันที ช่วยให้สามารถจำแนกรูปแบบการโจมตี เช่น การพยายามฉีดคำสั่ง SQL การทดสอบช่องโหว่ Cross-Site Scripting หรือการสแกนด้วยเครื่องมืออัตโนมัติ เมื่อตรวจพบความเสี่ยงในระดับวิกฤตระบบจะทำการสร้างข้อมูลสรุปในรูปแบบ JSON

และส่งผ่าน Discord Webhook ไปยังช่องทางการสื่อสารของผู้ดูแลระบบทันที ทำให้สามารถรับรู้สถานการณ์และตอบสนองต่อภัยคุกคามได้อย่างรวดเร็ว

บทที่ 3
วิธีดำเนินงาน

ในการจัดทำรายงานการออกแบบและพัฒนาระบบรักษาความมั่นคงปลอดภัยแบบหลายชั้น ได้จัดแบ่งขั้นตอนการปฏิบัติงานออกเป็นลำดับอย่างมีระบบ ตั้งแต่การวางโครงสร้างสถาปัตยกรรม การจัดตั้งระบบแม่ข่าย การปรับแต่งความปลอดภัยของเว็บเซิร์ฟเวอร์ ไปจนถึงการพัฒนาระบบเฝ้าระวังภัยคุกคาม โดยมีรายละเอียดดังต่อไปนี้

3.1 การออกแบบสถาปัตยกรรมระบบ 6 ระดับชั้น

เพื่อรองรับหลักการป้องกันเชิงลึก ระบบได้รับการออกแบบให้มีการแบ่งระดับชั้นการทำงานออกเป็น 6 ระดับอย่างเป็นเอกเทศ เพื่อให้การควบคุมความปลอดภัยในแต่ละชั้นสามารถทำงานสอดประสานกันได้อย่างสมบูรณ์ ดังแสดงในตารางที่ 3.1

ตารางที่ 3.1 สถาปัตยกรรมความมั่นคงปลอดภัยแบบหลายชั้น 6 ระดับ

ระดับชั้น (Layer)	เทคโนโลยี/เครื่องมือหลัก	บทบาทและหน้าที่การทำงาน
Layer 1: Perimeter & Cloud Network	DuckDNS, Azure NSG, IPset	แปลงชื่อโดเมน กรองพอร์ตเครือข่ายขาเข้า และปิดกั้น IP ต่างประเทศด้วย Geo-blocking
Layer 2: Host & Operating System	Ubuntu 24.04, Fail2Ban, SSH Key	ควบคุมสิทธิ์การเข้าถึงด้วยกุญแจคู่รหัส และตรวจจับการบุกรุกผ่าน sshd jail
Layer 3: Reverse Proxy & Gateway	Nginx, Let's Encrypt SSL/TLS	ถอดรหัส HTTPS, บังคับใช้ Security Headers, จำกัดอัตราคำขอ และบล็อกคำขออันตราย (HTTP 403)
Layer 4: Application Runtime	PHP 8.3-FPM, UNIX Domain Socket	ประมวลผลสคริปต์ PHP ผ่าน IPC Socket ที่ปลอดภัย และจำกัดสิทธิ์ในระดับโปรเซส
Layer 5: Application & CMS	WordPress 6.x, WP Armour	จัดการเนื้อหา สกัดกั้นการสืบค้นชื่อผู้ใช้ และใช้ Honeypot ป้องกันสแปมบอทระดับฟอร์ม

ระดับชั้น (Layer)	เทคโนโลยี/เครื่องมือหลัก	บทบาทและหน้าที่การทำงาน
Layer 6: Data Persistence	MySQL 8.0, Ext4 Filesystem	จัดเก็บฐานข้อมูลในเครื่องท้องถิ่น ปิดการเชื่อมต่อภายนอก และควบคุมสิทธิ์ของระบบไฟล์

3.2 การจัดเตรียมเครื่องแม่ข่ายเสมือนบนคลาวด์และการควบคุมสิทธิ์ SSH

ดำเนินการจัดตั้งเครื่องแม่ข่ายเสมือน (Virtual Machine) บนโครงสร้างพื้นฐานคลาวด์ของ Microsoft Azure โดยเลือกใช้ระบบปฏิบัติการ Ubuntu Server 24.04 LTS จากนั้นกำหนดค่านโยบายความปลอดภัยของเครือข่ายเสมือนผ่าน Network Security Group ให้เปิดรับการเชื่อมต่อเฉพาะพอร์ตบริการที่จำเป็น ได้แก่ พอร์ต 22 (SSH) พอร์ต 80 (HTTP) และพอร์ต 443 (HTTPS) ขณะที่พอร์ตบริการภายใน เช่น MySQL (พอร์ต 3306) จะถูกปิดกั้นจากการเข้าถึงภายนอกทั้งหมด

ในด้านการรักษาความปลอดภัยของระบบปฏิบัติการ ได้ดำเนินการกำหนดค่าการเข้าถึงระยะไกลผ่าน OpenSSH โดยบังคับใช้การยืนยันตัวตนด้วยกุญแจคู่รหัส (SSH Public Key Authentication) และปิดการยืนยันตัวตนด้วยรหัสผ่านแบบดั้งเดิม เพื่อป้องกันการโจมตีแบบเดาสุ่มรหัสผ่าน (Brute-Force Attack) ในระดับรากฐานของระบบ

3.3 การกำหนดค่าระบบแปลงชื่อโดเมนแบบพลวัต (DuckDNS)

ทำการลงทะเบียนชื่อโดเมน lynxlunarcs.duckdns.org ผ่านระบบบริการ DuckDNS และเขียนสคริปต์อัตโนมัติบนระบบปฏิบัติการ เพื่อส่งคำขอปรับปรุงหมายเลขไอพีแอดเดรสของเครื่องแม่ข่ายเสมือนไปยังเซิร์ฟเวอร์ของ DuckDNS ผ่านทางโปรโตคอล HTTPS REST API โดยกำหนดให้ทำงานเป็นประจำผ่านระบบตั้งเวลาของลินุกซ์ (Linux Crontab) เพื่อให้การเชื่อมโยงชื่อโดเมนมีความแม่นยำและพร้อมให้บริการอย่างสม่ำเสมอ

3.4 การติดตั้งและการกำหนดค่า Nginx Reverse Proxy และ SSL/TLS

ติดตั้งเว็บเซิร์ฟเวอร์ Nginx เพื่อทำหน้าที่เป็นตัวแทนย้อนกลับ (Reverse Proxy) ในการรับคำขอจากภายนอกและส่งต่อให้แก่ตัวประมวลผลแอปพลิเคชันภายใน พร้อมทั้งได้ติดตั้งใบรับรองความปลอดภัยดิจิทัลจาก Let's Encrypt ผ่านเครื่องมือ Certbot เพื่อเปิดใช้งานการเข้ารหัสลับข้อมูลผ่าน HTTPS (พอร์ต 443) และกำหนดให้ทำการเปลี่ยน

เส้นทางคำขอแบบ HTTP (พอร์ต 80) ไปยัง HTTPS โดยอัตโนมัติ (301 Permanent Redirect) โดยรองรับโปรโตคอล TLSv1.2 และ TLSv1.3 ที่มีความมั่นคงปลอดภัยสูง

3.5 การปรับแต่งความมั่นคงปลอดภัยของเว็บเซิร์ฟเวอร์ (Nginx Hardening)

เพื่อปิดกั้นช่องโหว่ความปลอดภัยระดับเว็บเซิร์ฟเวอร์ ได้ดำเนินการแก้ไขไฟล์และกำหนดค่า /etc/nginx/sites-available/lynxlunarcs.duckdns.org โดยมีมาตรการสำคัญดังนี้

3.5.1 การปิดการเปิดเผยเวอร์ชันของซอฟต์แวร์

กำหนดคำสั่ง server_tokens off เพื่อมิให้ระบบส่งค่ารุ่นของ Nginx และระบบปฏิบัติการในส่วนหัวของการตอบกลับ

3.5.2 การควบคุมอัตราการส่งคำขอ

กำหนดโซน limit_req_zone ขนาด 10 เมกะไบต์ จำกัดอัตราการส่งคำขอไว้ที่ 5 คำขอต่อวินาที เพื่อป้องกันการยิงถล่มคำขอแบบ DoS

3.5.3 การบังคับใช้ส่วนหัวความปลอดภัย HTTP Security Headers

กำหนดการส่งส่วนหัว Strict-Transport-Security (HSTS), X-Frame-Options (SAMEORIGIN), X-Content-Type-Options (nosniff), Referrer-Policy และ Content-Security-Policy (CSP)

3.5.4 การปิดกั้นการเข้าถึงไฟล์ระบบสำคัญ

กำหนดกฎบล็อกการเข้าถึงไฟล์ wp-config.php, xmlrpc.php, readme.html และ license.txt โดยตอบกลับด้วยรหัส HTTP 403 Forbidden

3.5.5 การสกัดกั้นการสืบค้นข้อมูลผู้ใช้งาน (User Enumeration)

กำหนดกฎบล็อกการเรียกดูรายชื่อผู้ใช้ผ่าน REST API (/wp-json/wp/v2/users) บล็อกการเข้าถึงหน้าคลังบทความผู้เขียน (/author/) และบล็อกคำขอที่มีพารามิเตอร์ ?author=N ด้วยรหัส HTTP 403 Forbidden ทันที

3.5.6 การป้องกันการรันโค้ดแปลกปลอมในไดเรกทอรีอัปโหลด

กำหนดกฎบล็อกการประมวลผลไฟล์สคริปต์ (เช่น .php, .sh, .cgi) ภายใต้ path /wp-content/uploads/

3.6 การติดตั้งระบบ WordPress และการเชื่อมโยง PHP-FPM

ดำเนินการติดตั้งแพ็กเกจ PHP 8.3-FPM และส่วนขยายที่จำเป็นสำหรับการทำงานของ WordPress จากนั้นกำหนดค่าให้ Nginx ส่งต่อคำขอไฟล์ภาษา PHP ไปยัง UNIX Domain Socket ที่พาธ /run/php/php8.3-fpm.sock ดำเนินการติดตั้งระบบ WordPress ภายใต้ไดเรกทอรี /var/www/html และกำหนดสิทธิ์การเป็นเจ้าของไฟล์ให้แก่ผู้ใช้ www-data พร้อมทั้งกำหนดสิทธิ์ของไดเรกทอรีเป็น 755 และสิทธิ์ของไฟล์เป็น 644 ตามมาตรฐานความปลอดภัย

ในระดับแอปพลิเคชัน ได้ดำเนินการติดตั้งปลั๊กอิน WP Armour – Honeypot Anti Spam เพื่อเสริมการป้องกันฟอร์มเข้าสู่ระบบและฟอร์มแสดงความคิดเห็น โดยสร้างฟิลด์ดักจับบอทที่ซ่อนจากสายตามนุษย์ ช่วยสกัดกั้นบอทสแปมได้อย่างมีประสิทธิภาพโดยไม่ส่งผลกระทบต่อความเร็วของระบบหรือความสะดวกของผู้ใช้งาน

3.7 การกำหนดค่าระบบป้องกันการบุกรุกและการปิดกั้นเชิงภูมิศาสตร์ (Geo-blocking)

ติดตั้งและเปิดใช้งานบริการ Fail2Ban เพื่อทำหน้าที่ตรวจสอบไฟล์บันทึกเหตุการณ์และสั่งการไฟร์วอลล์ โดยเปิดใช้งาน Jail หลักจำนวน 2 ตัว ได้แก่ sshd สำหรับตรวจจับการเดารหัสผ่านผิดพลาดบนพอร์ต SSH และ nginx-botsearch สำหรับตรวจจับคำขอที่พยายามสแกนหาไฟล์ช่องโหว่บนเว็บเซิร์ฟเวอร์ นอกจากนี้ยังได้ติดตั้ง IPset ร่วมกับฐานข้อมูลหมายเลขไอพีของประเทศไทย (Thailand IP Zone) เพื่อสร้างกฎไฟร์วอลล์ในการปิดกั้นทราฟฟิกที่ไม่พึงประสงค์จากต่างประเทศ

3.8 การพัฒนาระบบ AI Log Analysis และการเชื่อมต่อ Discord Webhook

เพื่อยกระดับการเฝ้าระวังระบบสู่รูปแบบอัตโนมัติ จึงได้พัฒนาโปรแกรมภาษาไพทอน ai_scanner.py ทำหน้าที่เป็นบริการเบื้องหลัง (Background Service) คอยอ่านไฟล์บันทึกเหตุการณ์ /var/log/nginx/access.log แบบทันกาล โดยใช้หลักการตรวจสอบรูปแบบความผิดปกติ (Heuristic Pattern Matching) เพื่อตรวจจับพฤติกรรมเสี่ยง เช่น การส่งพารามิเตอร์ SQL Injection การแทรกสคริปต์ Cross-Site Scripting (XSS) และการสแกนด้วยเครื่องมืออัตโนมัติ เมื่อตรวจพบเหตุการณ์อันตรายระบบจะสร้างข้อความรายงานในรูปแบบ JSON และส่งสัญญาณแจ้งเตือนผ่าน Discord Webhook ไปยังช่องทางการสื่อสารของผู้ดูแลระบบในทันที

บทที่ 4
ผลการดำเนินงาน

ในการจัดทำรายงานการออกแบบและพัฒนาระบบรักษาความมั่นคงปลอดภัยแบบหลายชั้น คณะผู้จัดทำได้ดำเนินการทดสอบและประเมินผลการทำงานของระบบในสภาวะการทำงานจริง โดยมีผลการดำเนินงานดังนี้

4.1 ผลการทดสอบสถานะการทำงานของระบบ

ผลการตรวจสอบสถานะการทำงานของบริการหลักบนเครื่องแม่ข่ายเสมือนผ่านคำสั่ง systemctl status พบว่าบริการทั้งหมดสามารถเริ่มต้นการทำงานได้อย่างถูกต้อง มีสถานะ active (running) และใช้ทรัพยากรระบบอย่างคุ้มค่า ดังแสดงในตารางที่ 4.1

ตารางที่ 4.1 สถานการณ์ทำงานใช้ทรัพยากรของบริการระบบ

ชื่อบริการระบบ	สถานะการทำงาน	พอร์ต	การใช้หน่วยความจำ (RAM)
nginx.service	active (running)	Port 80, 443	7.7 MB (เสถียรภาพสูง)
fail2ban.service	active (running)	Jails: sshd, botsearch	20.9 MB
php8.3-fpm.service	active (running)	unix:/run/php/php8.3-fpm.sock	18.5 MB
mysql.service	active (running)	127.0.0.1:3306 (Local Only)	245.0 MB

4.2 ผลการทดสอบการเข้าถึงเว็บไซต์และใบรับรองความปลอดภัย

จากการทดสอบเปิดหน้าเว็บไซต์ https://lynxlunarcs.duckdns.org ผ่านเครือข่ายอินเทอร์เน็ตภายในประเทศ พบว่าหน้าเว็บประชาสัมพันธ์หลักสูตรสามารถแสดงผลได้อย่างสมบูรณ์ มีสัญลักษณ์แม่กุญแจแสดงสถานะความปลอดภัย และใบรับรองอิเล็กทรอนิกส์ได้รับการรับรองความถูกต้องจาก Let's Encrypt อย่างสมบูรณ์

4.3 ผลการทดสอบระบบควบคุมขอบเขตตามภูมิศาสตร์ (Geo-blocking)

ในการทดสอบประสิทธิภาพของการปิดกั้นการเชื่อมต่อจากต่างประเทศ คณะผู้จัดทำได้ใช้เครือข่ายเสมือนส่วนตัว (VPN) จำลองการเชื่อมต่อไปยังโหนดในต่างประเทศ (สิงคโปร์และสหรัฐอเมริกา) แล้วพยายามเข้าถึงเว็บไซต์ ผลปรากฏว่าหน้าเว็บแจ้งสถานะ Connection Timed Out เนื่องจากเคอร์เนลสั่ง DROP แพ็กเก็ตตามกฎ iptables ตั้งแต่แรก สรุปผลการทดสอบแสดงดังตารางที่ 4.2

ตารางที่ 4.2 ผลการทดสอบระบบความปลอดภัยและไฟร์วอลล์ในสถานการณ์ต่าง ๆ

สถานการณ์การทดสอบ	แหล่งที่มาของทราฟฟิก	พอร์ตเป้าหมาย	ผลการทดสอบจริง
การใช้งานปกติในประเทศ	active (running)	Port 80, 443	7.7 MB (เสถียรภาพสูง)
การเข้าถึงจากต่างประเทศ	VPN (สิงคโปร์/สหรัฐอเมริกา)	Port 80, 443	บล็อกสำเร็จ (DROP / Connection Timed Out)
การสแกนหาไฟล์ช่องโหว่	ส่งคำขอเรียกไฟล์ /wp-admin, .env	Port 443	สกัดกั้นสำเร็จ (ตอบกลับ 403 Forbidden)
การยิงคำขอความถี่สูง	ทดสอบส่งคำขอ เกิน 5 ครั้ง/วินาที	Port 443	จำกัดความเร็วสำเร็จ (Rate Limit ป้องกัน DoS)
การสั่งระงับการเชื่อมต่อ	ai_scanner.py ตรวจพบ พฤติกรรมเสี่ยง	ทุกพอร์ต	แบนไอพีลง ipset blacklist สำเร็จ

4.4 ผลการทดสอบการสกัดกั้นช่องโหว่ความปลอดภัยระดับเว็บเซิร์ฟเวอร์

ได้ทำการทดสอบส่งคำขอจำลองการโจมตีผ่านคำสั่ง curl -I ไปยัง Endpoint สำคัญของระบบ ผลการตอบสนองของ Nginx แสดงดังตารางที่ 4.3

ตารางที่ 4.3 ผลการทดสอบการสกัดกั้นช่องโหว่ความปลอดภัยระดับเว็บเซิร์ฟเวอร์

เป้าหมายการทดสอบ (Endpoint)	ลักษณะการทดสอบ	ผลสถานะตอบกลับ
/wp-config.php	เรียกดูไฟล์กำหนดค่าฐานข้อมูล	HTTP 403 Forbidden
/xmlrpc.php	ทดสอบเรียกใช้อินเทอร์เฟซ XML-RPC	HTTP 403 Forbidden
/wp-json/wp/v2/users	ดึงรายชื่อผู้ใช้ผ่าน REST API	HTTP 403 Forbidden
/author/phum/	สืบค้นชื่อบัญชีผู้ดูแลผ่าน URL	HTTP 403 Forbidden
Server Response Header	ตรวจสอบ Banner Grabbing	Server: nginx

4.5 ผลการทดสอบระบบตรวจจับ AI Log และการสั่งระงับการเชื่อมต่ออัตโนมัติ

เมื่อจำลองการส่งคำขอสแกนหาช่องโหว่ สคริปต์ ai_scanner.py สามารถตรวจพบบันทึกการเข้าถึงที่ผิดปกติและประเมินระดับความเสี่ยงเป็น High Risk พร้อมทั้งส่งรายงานสรุปผลเข้าสู่ Discord Channel แบบทันที และเมื่อตรวจสอบตารางแบล็กลิสต์ด้วยคำสั่ง sudo ipset list blacklist พบว่าไอพีของผู้โจมตีถูกเพิ่มเข้าสู่ตารางแบล็กลิสต์ของไฟร์วอลล์โดยอัตโนมัติ ทำให้การเชื่อมต่อครั้งต่อไปจากไอพีดังกล่าว ถูกบล็อกทิ้งทันทีในระดับเคอร์เนล

บทที่ 5
สรุปผลและข้อเสนอแนะ

5.1 สรุปผลการดำเนินงาน

การดำเนินงานโครงงานการออกแบบและพัฒนาระบบรักษาความมั่นคงปลอดภัยแบบหลายชั้น (Multi-Layered Defense-in-Depth) สำหรับระบบจัดการเนื้อหาบนคลาวด์ ได้บรรลุผลสำเร็จตามวัตถุประสงค์ที่กำหนดไว้ทุกประการ ระบบสามารถบูรณาการการทำงานร่วมกันระหว่าง Microsoft Azure VPS, DuckDNS, Nginx Reverse Proxy, PHP 8.3-FPM, MySQL 8.0, Fail2Ban, IPset และ WP Armour ได้อย่างมีเสถียรภาพ

ผลการทดสอบเชิงลึกยืนยันว่า กลไกการป้องกันในแต่ละระดับชั้นสามารถสกัดกั้นช่องโหว่ความปลอดภัยได้อย่างเด็ดขาด โดยเฉพาะการปิดกั้นการเข้าถึงไฟล์ระบบสำคัญ การสกัดกั้นการสืบค้นชื่อบัญชีผู้ดูแลระบบ (User Enumeration) และการตัดวงจรการโจมตีผ่าน XML-RPC ด้วยรหัสตอบกลับ HTTP 403 Forbidden ตั้งแต่ระดับเว็บเซิร์ฟเวอร์ Nginx ทำให้เครื่องแม่ข่ายสามารถประหยัดทรัพยากรการประมวลผลได้อย่างมีประสิทธิภาพ นอกจากนี้ ระบบตรวจจับและแจ้งเตือนภัยคุกคามผ่าน AI Log Analysis และ Discord Webhook ยังช่วยให้การเฝ้าระวังระบบเป็นไปอย่างอัตโนมัติ

5.2 ข้อเสนอแนะสำหรับการพัฒนาต่อยอด

5.2.1 การเชื่อมโยง Web Application Firewall (WAF) บนระบบคลาวด์

ในอนาคตสามารถพิจารณาเชื่อมต่อร่วมกับบริการคลาวด์เช่น Cloudflare หรือ Azure Front Door เพื่อช่วยบรรเทาการโจมตีแบบปฏิเสธการให้บริการแบบกระจายขนาดใหญ่ในระดับชั้นเครือข่าย ก่อนที่ทราฟฟิกจะมาถึงเครื่องแม่ข่ายเสมือน

5.2.2 การประยุกต์ใช้แบบจำลองการเรียนรู้ของเครื่อง (Machine Learning)

สามารถพัฒนาต่อยอดโปรแกรมวิเคราะห์บันทึกเหตุการณ์ให้ใช้แบบจำลอง (Machine Learning) เช่น Isolation Forest ในการตรวจจับความผิดปกติของทราฟฟิกแบบอัตโนมัติ โดยไม่ต้องพึ่งพากฎเกณฑ์เฉพาะเจาะจง เพื่อรองรับการตรวจจับภัยคุกคามรูปแบบใหม่ (Zero-day Attacks)

5.2.3 การจัดทำระบบสำรองข้อมูลอัตโนมัติแบบเข้ารหัส

ควรติดตั้งสคริปต์สำรองข้อมูลฐานข้อมูล และไฟล์เว็บไซต์ไปยังบริการจัดเก็บบนคลาวด์ (เช่น Azure Blob Storage) เป็นประจำทุกวันพร้อมทั้งเข้ารหัสไฟล์สำรองข้อมูลเพื่อความพร้อมในการกู้คืนระบบเมื่อเกิดภัยพิบัติ

5.2.4 การบังคับใช้การยืนยันตัวตนแบบหลายปัจจัย (Multi-Factor Authentication: MFA)

เสริมความปลอดภัยในการเข้าสู่ระบบหลังบ้านของ WordPress ด้วยการยืนยันตัวตนผ่านรหัสผ่านแบบใช้ครั้งเดียวตามเวลา (TOTP) เพื่อป้องกันการถูกสวมรอยสิทธิ์ในกรณีที่รหัสผ่านเกิดการรั่วไหล

บรรณานุกรม

Open Web Application Security Project (OWASP). (2024). OWASP Top 10 Web Application Security Risks. สืบค้นจาก https://owasp.org/www-project-top-ten/

Nginx Inc. (2025). Nginx Reverse Proxy and Security Hardening Documentation. สืบค้นจาก https://nginx.org/en/docs/

WordPress.org. (2025). Hardening WordPress: Best Practices for Site Security. สืบค้นจาก https://wordpress.org/documentation/article/hardening- wordpress/

Fail2Ban Development Team. (2024). Fail2Ban System and Log Monitoring Architecture. สืบค้นจาก https://www.fail2ban.org/

Internet Engineering Task Force (IETF). (2022). RFC 9116: A Format to Specify Security Policy for Web Sites. สืบค้นจาก https://datatracker.ietf.org/doc/html/rfc9116